

Cyber Threat Intelligence Report

05th of March 2026

TLP:CLEAR - May be shared publicly

StegaBin: Typosquatted npm Packages Steal Developer Credentials and Install a RAT

Risk Level

☐ CRITICAL

☑ HIGH

☐ MEDIUM

☐ LOW

Report ID

TW-CTI-2026-001

Malware Overview

Malware Family: StegaBin credential stealer and RAT

Threat Actor: FAMOUS CHOLLIMA (North Korea-linked; Socket assesses it as consistent with this actor)

Initial Access Vector: 26 typosquatted npm packages with an install script

First Seen: 25-26 February 2026

Region: Global

Impact

Who is affected: Developers and build systems that installed any of the 26 packages listed on the indicators slide. Web3 and cryptocurrency developers appear to be the main targets.

The packages run during npm install and deploy a remote access trojan and a nine-module toolkit. It steals browser credentials, cryptocurrency wallet data, SSH keys, Git credentials and secrets found on disk, and it re-runs itself whenever a VS Code project is opened. One install can expose source code, repository and cloud access, and wallets. Rated HIGH for any team that installed an affected package.

MALWARE OBJECTIVES AND KILL CHAIN

Objectives

- **Steal developer credentials:** Git tokens, SSH keys, browser passwords and API secrets.
- **Harvest wallet data:** cryptocurrency wallet data and files that may hold seed phrases or private keys.
- **Keep access:** a lightweight RAT gives the operator remote control.
- **Persist:** npm install hooks and a VS Code task that runs whenever a folder is opened.
- **Collect code and secrets:** Git repository details, Git credentials and sensitive files.

Kill Chain

- **Preparation:** The actor imitated popular npm libraries (web frameworks, database clients, authentication and crypto packages) and published 26 look-alike packages from throwaway accounts on 25-26 February 2026.

- **Delivery:** Names such as fastify-lint and expressjs-lint resemble real tools. Each package also declares the real library as a dependency, so a project may still build normally after an accidental install.

- **Execution:** npm install runs scripts/test/install.js, which loads an obfuscated loader. The loader reads three Pastebin pages and decodes hidden command-and-control addresses from them using text steganography.

- **Installation and control:** The decoded Vercel domains serve OS-specific shell payloads. A token-gated script installs Node.js and Python if needed, starts a RAT (parser.js) that connects to 103[.]106[.]67[.]63:1244, and deletes itself.

- **Actions on objectives:** The server pushes nine modules that log keystrokes and the clipboard, steal browser and wallet data, scan the disk for secrets, copy SSH keys and Git credentials, and add a VS Code task that re-runs the malware.

TECHNICAL DETAILS

Socket reported 26 malicious npm packages published over 25-26 February 2026 from throwaway accounts. They imitate widely used libraries, and eight carry a -lint suffix. Each declares the genuine library as a dependency and runs node ./scripts/test/install.js during installation. That script loads a shared, heavily obfuscated file, vendor/scrypt-js/version.js, which uses RC4 string encryption, array rotation, anti-debugging and control-flow flattening.

The loader fetches three Pastebin pages that look like ordinary computer science essays. Characters at evenly spaced positions have been replaced to spell out 31 Vercel-hosted domains, and only one was serving payloads when Socket analysed it. The malware requests a payload for the host OS (curl on macOS and Windows, wget on Linux). A token-gated bootstrapper then installs Node.js and Python if needed, downloads parser.js, runs it in the background and removes itself.

parser.js is a simple RAT that connects to 103[.]106[.]67[.]63:1244 and supports changing directory and running shell commands. Socket simulated an infected host and observed the server deploy nine modules: a keylogger and clipboard stealer, a Python browser stealer, a cryptocurrency wallet stealer, file-search and FTP exfiltration tools, a TruffleHog scan of the filesystem, and Git and SSH key theft. Persistence uses a user-level VS Code tasks.json whose command is hidden behind 186 leading spaces and set to run whenever a folder is opened.

INDICATORS OF COMPROMISE

Malicious npm packages (26)

- formmiderable@3.5.7
- bubble-core@6.26.2
- mqttoken@5.40.2
- windowston@3.19.2
- bee-quarl@2.1.2
- kafkajs-lint@2.21.3
- jslint-config@10.22.2
- zoddle@4.4.2
- daytonjs@1.11.20
- corstoken@2.14.7
- jsnwebapptoken@8.40.2
- iosysredis@5.13.2
- sequelization@6.40.2
- undicy-lint@7.23.1
- expressjs-lint@5.3.2
- loadash-lint@4.17.24
- promanage@6.0.21
- vitetest-lint@4.1.21
- prism-lint@7.4.2
- fastify-lint@5.8.0
- typoriem@0.4.17
- argonist@0.41.0
- uuindex@13.1.0
- bcryptance@6.5.2
- hapi-lint@19.1.2
- ether-lint@5.9.4

Domains

- ext-checkdin[.]vercel[.]app
- cleverstack-ext301[.]vercel[.]app
- cleverstack-app998[.]vercel[.]app
- brightlaunch-ext742[.]vercel[.]app
- brightlaunch-app615[.]vercel[.]app
- primevector-ext483[.]vercel[.]app
- primevector-app920[.]vercel[.]app
- zenithflow-ext156[.]vercel[.]app

...and 23 more in iocs.csv

The complete list (70 indicators) is provided in the accompanying iocs.csv file.

Host artifacts

- A user-level VS Code tasks.json with a command hidden behind a very long run of spaces, set to run on folder open
- A copy of the vendor/scrypt-js/version.js loader redeployed on the host
- Connections to 103[.]106[.]67[.]63 on ports 1244 and 1247

URLs

- hxxps://pastebin[.]com/CJ5PrtNk
- hxxps://pastebin[.]com/0ec7i68M
- hxxps://pastebin[.]com/DjDCxcsT

IPs

- 103[.]106[.]67[.]63

Hashes (SHA256)

- ddbb527be0f40cd13eab08e3e418e36e86e4f1f1458cf84cfee29490beacf3a6
- ce80100a383730822221f3ce769ea5ccda0c583654cc7c119ecc50bfbb4203b9
- 714f890308d2cfebb2ed3ae873697408372639260bb682ea4cfbfffec98b8add
- 1b15f73054350c6ab42f6e1d2ce4d84d7c56821db699e4ec484541263dfcb636
- ba3e520b9727e893cf07b0c1a6e6ce1a62e8e9bf28b5c771af4fdf01f9bd9ed4
- 78c8b9044f6029280d28a1f62a4414a22e870fc27e3cc4894bd077d17f2ad8b4
- 4e6a7bf3964fc0e3a655f062330c76b4876dcfac47d213e4c1f0ec3fe6ef9e12
- 978e8f161da04e00117a695aa59452dce89b5247db93ab7cedcaea3c1f26b8c8
- da1775d0fbe99fbc35b6f0b4a3a3cb84da3ca1b2c1bbac0842317f6f804e30a4

Recommendations and References

Recommendations

- **Today:** Search lockfiles (package-lock.json, yarn.lock, pnpm-lock.yaml) and CI logs for the 26 packages listed on the indicators slide.
- **If you find a match:** Treat the machine as compromised. Isolate it, rotate Git tokens, SSH keys, API secrets and saved browser passwords, and move funds out of any wallets on it.
- **Check VS Code:** Look in the user-level tasks.json for a task with a very long run of leading spaces, or one set to run when a folder opens, and remove it.
- **Hunt in logs:** Search DNS, proxy and EDR data for the listed Vercel domains, the Pastebin URLs and 103[.]106[.]67[.]63 (ports 1244 and 1247).
- **This week:** Limit install-script risk on developer machines and in CI (for example npm install --ignore-scripts, or an allow-list) and pin dependency versions.
- **Ongoing:** Review new dependencies and check package names for small misspellings before installing.

References

- https://socket.dev/blog/stegabin-26-malicious-npm-packages-use-pastebin-steganography
- https://kmsec.uk/blog/dprk-text-steganography/
- https://thehackernews.com/2026/03/north-korean-hackers-publish-26-npm.html
- https://gbhackers.com/new-stegabin-campaign/

STAY VIGILANT

Implement these recommendations to protect your organization from this threat.

For Support

Email: info@threatwire-intelligence.com

© 2026 Threat Wire. All Rights Reserved.